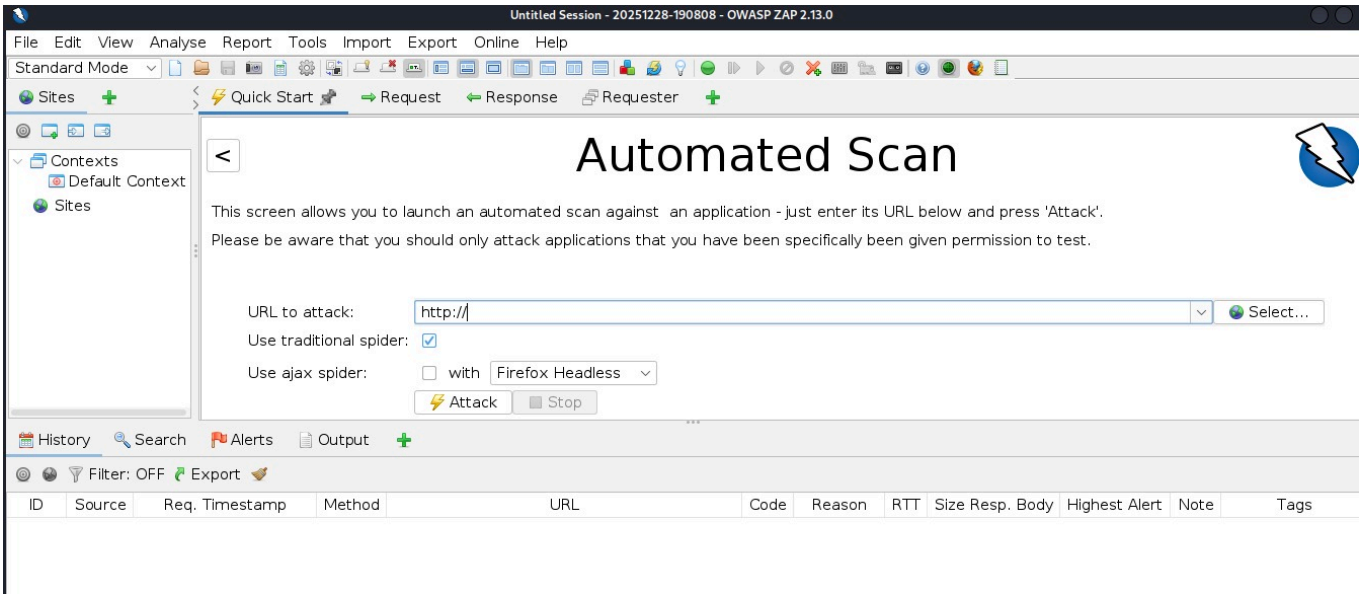
INTRODUCTION TO OWASP ZAP

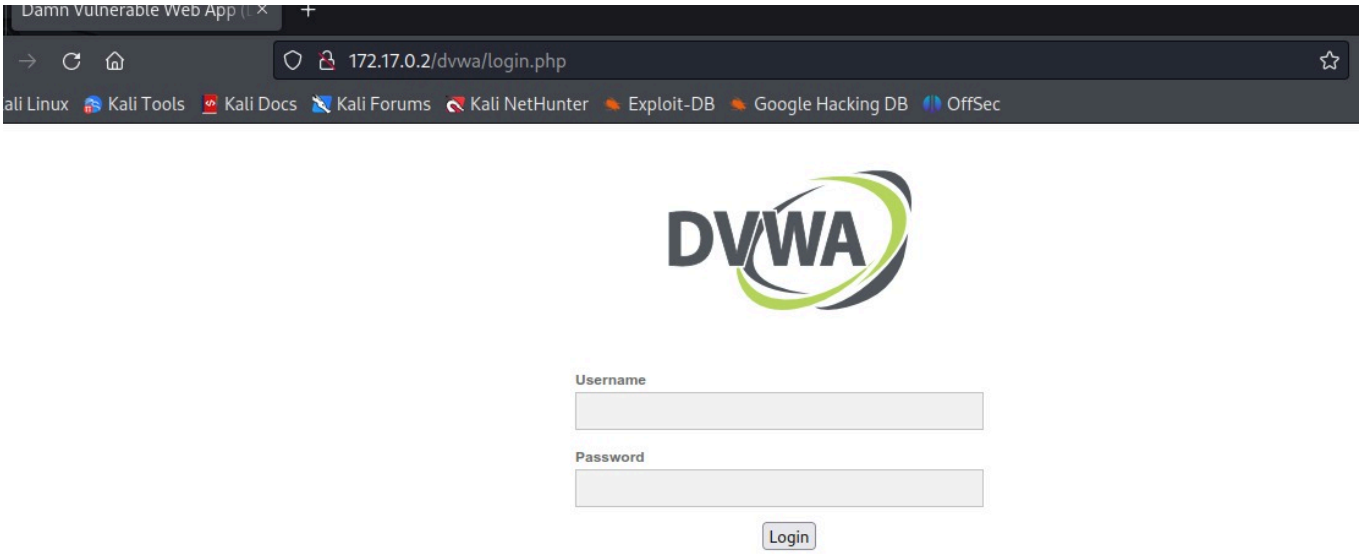
OWASP ZAP is a penetration tool that helps developers and security professionals detect and find vulnerabilities in web applications. OWASP ZAP performs security functions including ;

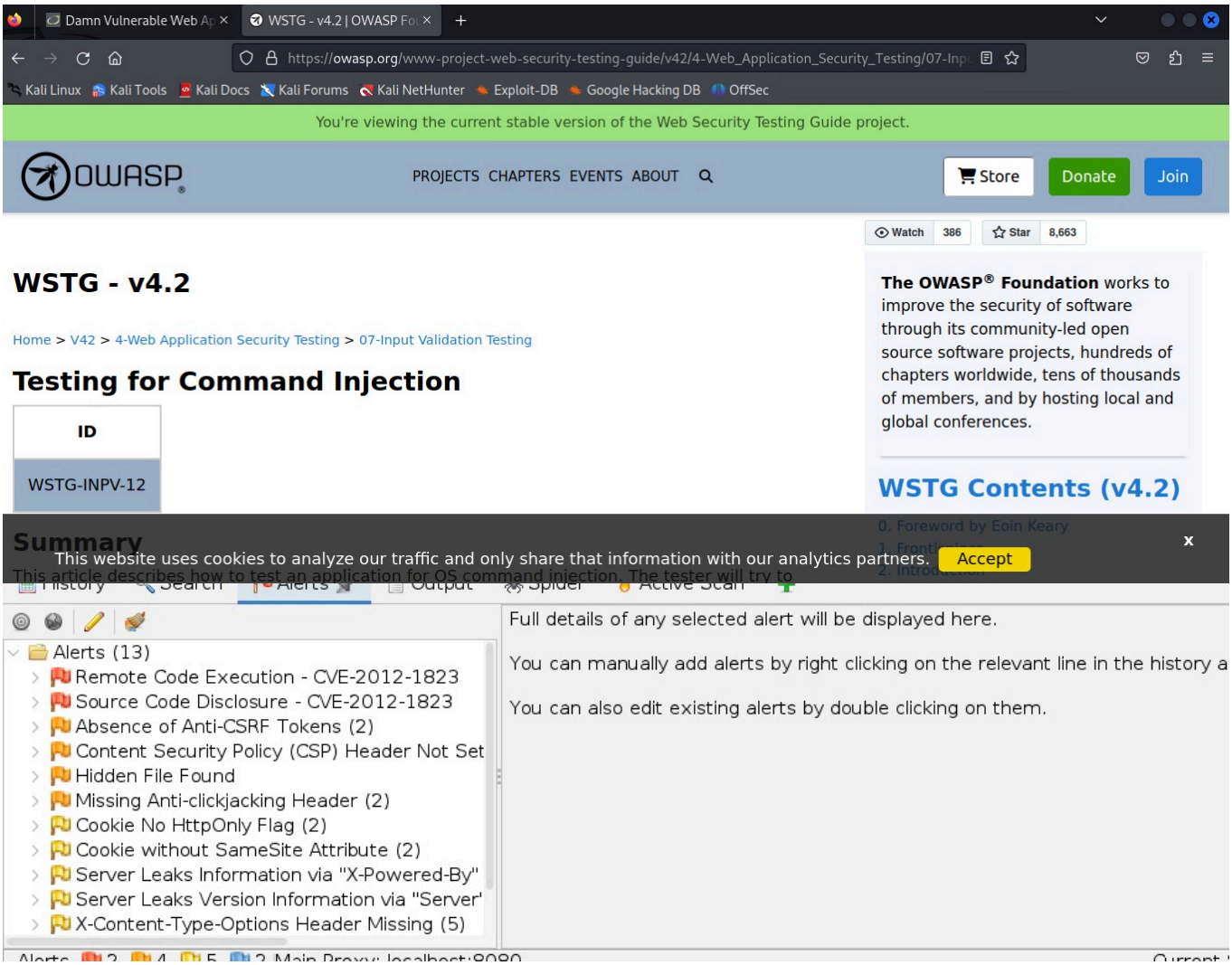
1. Passively scanning web requests
2. Using dictionary lists to search for files and folders on web servers.
3. Using crawlers to identify a site's structure and retrieve all links and URL's
4. Intercepting,displaying,modifying and forwarding web requests between browsers and web applications

OWASP ZAP can identify vulnerabilities in web applications including compromised authentication,exposure to sensitive data,security misconfigurations,SQL injection, cross-site scripting and other components with vulnerabilities.
ZAP provides two spiders for scraping web applications , which you can select in the automated scan dialog and these are the traditional zap spiders which inspects HTML in web applications's response to detect links and also the ZAP AJAX spider which is more used in javascript applications.

It navigates a web application by invoking a browser , rendering the full javascript application of the page and following any links on the resulting page.







The diagrams above shows or illustrates the usage of OWASP ZAP on the Damn Vulnerable Web Application. It has been proven that the ZAP can identify real world web vulnerabilities in the application.

NOTE: Please use this tool on applications you own or have permission to test